



AURORA
— MARKET —

TU TIENDA. TU CONFIANZA. **TU SEGURIDAD.**

ACTIVIDAD 01

ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

**MARÍA YULIBETH
GRANADA CUEVAS**



HACKER WOMEN
COUNCIL —
ETHICAL HACKING

05 DE SEPTIEMBRE DE 2026

01 ANTECEDENTES

Aurora Market es una **plataforma de comercio electrónico** en rápido crecimiento que gestiona **información sensible** de sus usuarios (**datos personales, historial de compras, direcciones de envío y correos electrónicos**). Recientemente, el área de **Atención al Cliente** recibió un reporte indicando que un usuario **visualizó información perteneciente a otra cuenta**. Tras una revisión interna, **el equipo no logró determinar la causa raíz** de la anomalía (descartando si fue un **error de la aplicación, fallo de permisos o un incidente de seguridad**).

A raíz de este evento, la dirección de **Aurora Market** ha solicitado una **auditoría de seguridad** para evaluar el **estado actual de la plataforma web**, entender su **superficie de ataque** y **cuantificar el riesgo real de exposición de datos**.

02 OBJETIVOS DE LA EVALUACIÓN

01

Determinar la superficie de ataque real de la plataforma web, identificando puntos de entrada, endpoints, flujos de datos sensibles y tecnologías expuestas.



02

Evaluar la existencia, explotabilidad e impacto de vulnerabilidades que permitan acceso no autorizado a información de otras cuentas.



03

Entregar recomendaciones priorizadas de hardening y remediación que permitan a Aurora Market reducir la superficie de ataque y mejorar su postura de seguridad.



03

ALCANCE DE LA EVALUACIÓN

EN ALCANCE

- Plataforma web de Aurora Market (aplicación de comercio electrónico orientada a clientes y sección destinada al personal de la empresa para administración de productos, usuarios y pedidos).
- Mecanismos de autenticación, autorización, gestión de cuentas, carrito de compras, consulta de pedidos y flujos relacionados con datos de clientes.



FUERA DEL ALCANCE

- Redes sociales de la empresa.
- Dispositivos o equipos personales de empleados.
- Cuentas de correo electrónico.
- Proveedores externos o sistemas que no formen parte de la plataforma web.
- Cualquier acción que interrumpa o degrade el funcionamiento de la plataforma.
- Manipulación, modificación o afectación de la información real de clientes (datos personales, historial de compras, pedidos, etc.).



PERMISOS REQUERIDOS:

- Autorización escrita para realizar reconocimiento pasivo y, cuando corresponda, reconocimiento activo sobre activos autorizados.
- Autorización para utilizar herramientas de descubrimiento y análisis dentro de límites acordados.
- Autorización para ejecutar pruebas autenticadas con cuentas de prueba proporcionadas por Aurora Market.
- Autorización para documentar y almacenar evidencia técnica necesaria para el informe.

CONDICIONES ACORDADAS:

- Evaluación limitada exclusivamente a la plataforma web.
- Prohibición de afectar la información de los clientes.
- Prohibición de atacar activos fuera del alcance definido.
- Entrega de informe técnico detallado con evidencias, evaluación de riesgo de negocio y propuestas de hardening.
- Ventanas de prueba en horarios de menor tráfico.

GRAY BOX - PENTEST DE CAJA GRIS

- El cliente proporcionó información parcial: la existencia de la plataforma web, base de datos, mecanismos de autenticación y diferentes tipos de usuarios (clientes y personal administrativo).
- No se entregó código fuente, diagramas de arquitectura detallados o credenciales de administrador.

**OBJETIVOS**

- Determinar la superficie de ataque real de la plataforma web, identificando puntos de entrada, endpoints, flujos de datos sensibles y tecnologías expuestas.
- Evaluar la existencia, explotabilidad e impacto de vulnerabilidades que permitan acceso no autorizado a información de otras cuentas.
- Entregar recomendaciones priorizadas de hardening y remediación que permitan a Aurora Market reducir la superficie de ataque y mejorar su postura de seguridad.

ALCANCE

- Dentro de alcance: Plataforma web de comercio electrónico, flujos de autenticación, catálogo, carrito, gestión de pedidos y portal de administración de empleados.
- Fuera de alcance: Redes sociales corporativas, dispositivos personales de colaboradores, cuentas de correo electrónico y proveedores externos.

PERMISOS Y CONDICIONES

- Permisos requeridos: Autorización formal y por escrito para ejecutar reconocimiento pasivo y activo, análisis automatizados controlados, pruebas de autenticación mediante cuentas de prueba provistas por Aurora Market y el almacenamiento seguro de la evidencia técnica necesaria para la auditoría.
- Condiciones acordadas: La evaluación se restringe estrictamente a la plataforma web sin intervenir activos fuera de alcance, protegiendo en todo momento la confidencialidad de los datos de los clientes, operando en horarios de bajo tráfico para no afectar la disponibilidad del servicio.

METODOLOGÍA A UTILIZAR

- Guía de Pruebas de Seguridad Web de OWASP (WSTG v4.2) complementada con el estándar PTES (Penetration Testing Execution Standard).

RECOPIACIÓN DE INFORMACIÓN PREVIA

- ·Dominios, URLs, subdominios e IPs autorizadas.
- ·Ambientes disponibles: producción, staging, QA o laboratorio.
- ·Cuentas de prueba tipo cliente y de empleados o administradores.
- ·Contactos de emergencia.

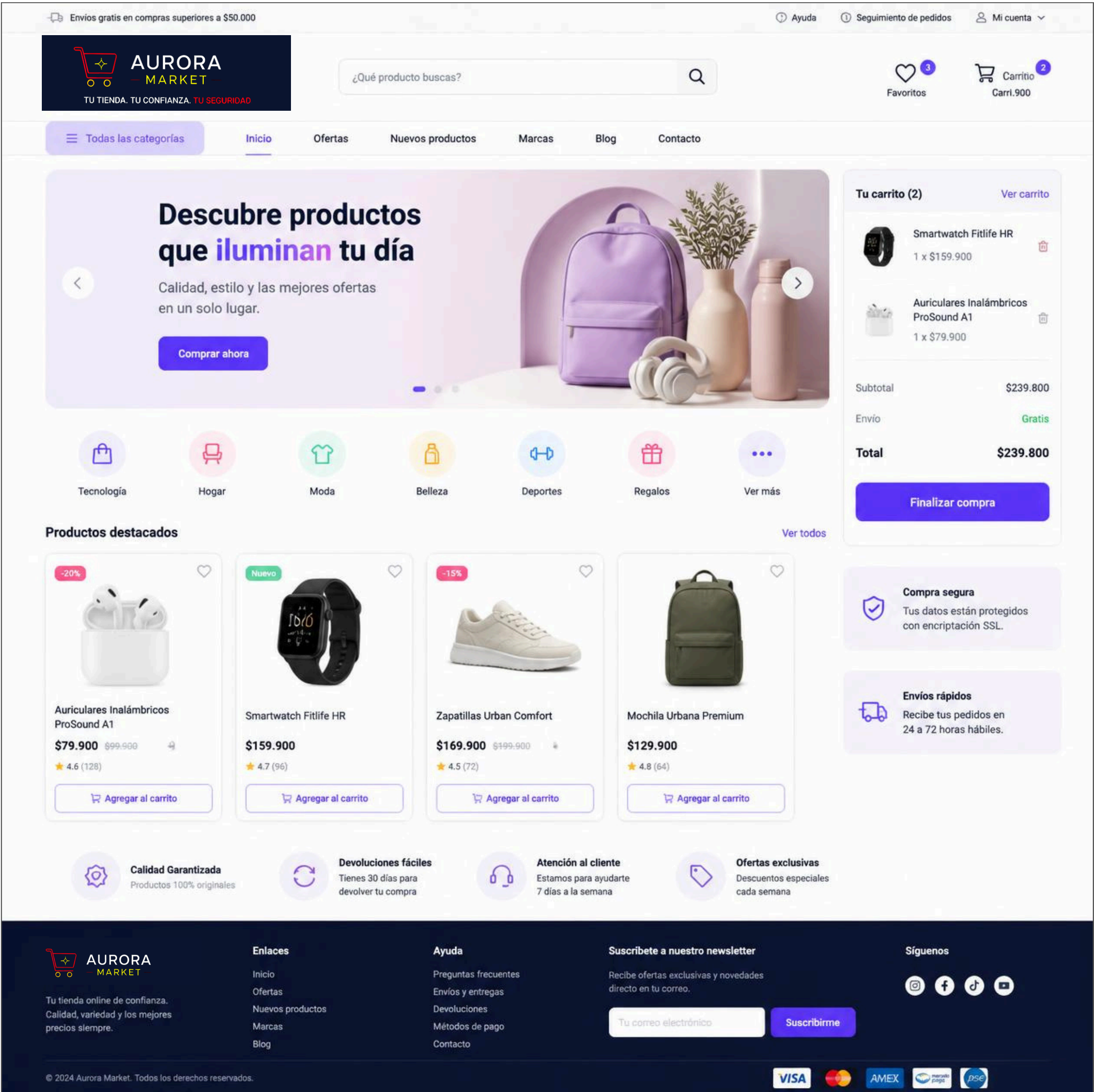
RECURSOS NECESARIOS

- Infraestructura y herramientas: Personal y entorno de trabajo controlado.
- Accesos de prueba: Cuentas de prueba de usuarios para validar aislamiento horizontal entre clientes, administradores y un contacto con acceso a la infraestructura para monitorear incidentes.





FASE	APLICACIÓN EN AURORA MARKET
1. Recopilación de Información	Mapeo pasivo de la superficie externa, fingerprinting de tecnologías y descubrimiento de endpoints clave (autenticación, catálogo, carrito, consulta de pedidos y panel administrativo de empleados).
2. Modelado de Amenazas	Identificación de activos críticos (datos personales, historial de compras) y priorización de vectores de riesgo: escalación horizontal (ver cuentas ajenas) y vertical (acceso de cliente a empleado).
3. Análisis de Vulnerabilidades	Auditoría exhaustiva de controles de acceso para localizar fallos de autorización (IDOR/BOLA) en identificadores de pedidos, revisión de gestión de sesiones y validación de permisos entre roles.
4. Explotación	Validación del incidente reportado reproduciendo el acceso no autorizado únicamente entre las dos cuentas de prueba sintéticas, garantizando cero afectación a datos de clientes reales.
5. Post-Explotación y Riesgo	Evaluación del impacto real hacia el negocio en caso de sufrir un ataque: suplantación de identidad o desvío no autorizado de mercancía.
6. Reporte y Hardening	Entrega del informe técnico detallando la causa raíz del fallo y recomendaciones de remediación.



**METODOLOGÍA ELEGIDA:**

Para el caso de Aurora Market, combinar PTES con las metodologías de OWASP resulta útil porque ambas se complementan. PTES permite organizar el pentest de forma estructurada, desde el reconocimiento y análisis de vulnerabilidades hasta la explotación controlada y la elaboración del informe. Esto ayuda a mantener las pruebas dentro del alcance autorizado y a reducir riesgos durante la evaluación.

Por su parte, OWASP está más enfocada en la seguridad de aplicaciones web, por lo que permite definir qué aspectos revisar dentro de Aurora Market, como autenticación, sesiones, autorización, control de acceso, validación de entradas, lógica de negocio y APIs. Esto es especialmente importante por el incidente reportado, ya que permite investigar de manera ordenada si realmente existe un problema que permita acceder a información de otras cuentas.

En conjunto, PTES aporta la estructura del proceso y OWASP proporciona una guía más específica para evaluar la aplicación web. De esta manera, es posible realizar una evaluación más completa y obtener resultados que no solo identifiquen vulnerabilidades, sino que también permitan comprender su impacto y definir medidas de mitigación.

